Suspicious Sign-In Investigation Report

By

Oluwatobi Babalola

Account Compromise & Credential Theft Investigation

Subject: Erwin Smith — Financial Analyst | Incident Period: 25 July – 1 August 2023

EXECUTIVE SUMMARY

A number of suspicious login attempts were detected on the account of Erwin Smith, Financial Analyst, from 30 July to 31 July 2023. An examination of the sign-in and activity logs verified that Erwin's credentials had been compromised, allowing an unauthorized third party to successfully infiltrate the organization's Microsoft 365 environment via malicious infrastructure based in Bulgaria and China.

The attacker accessed two highly sensitive documents: the organization's vulnerability report for June 2023 and the current payroll spreadsheet. Both documents were accessed, and the payroll file was downloaded. The concurrent legitimate activity from Erwin's recognized UK IP address during this timeframe confirms that this was indeed a credential compromise, as Erwin's account was accessed by an attacker while he was actively engaged in work.

Additionally, a secondary finding revealed the presence of unauthorized mouse-jiggling software (caffeine.exe) on Erwin's device, which represents a distinct policy violation that necessitates further investigation.

VERDICT CONFIRMED COMPROMISE	SEVERITY CRITICAL	DATA EXFILTRATED YES — 2 files

2. INVESTIGATION STEPS

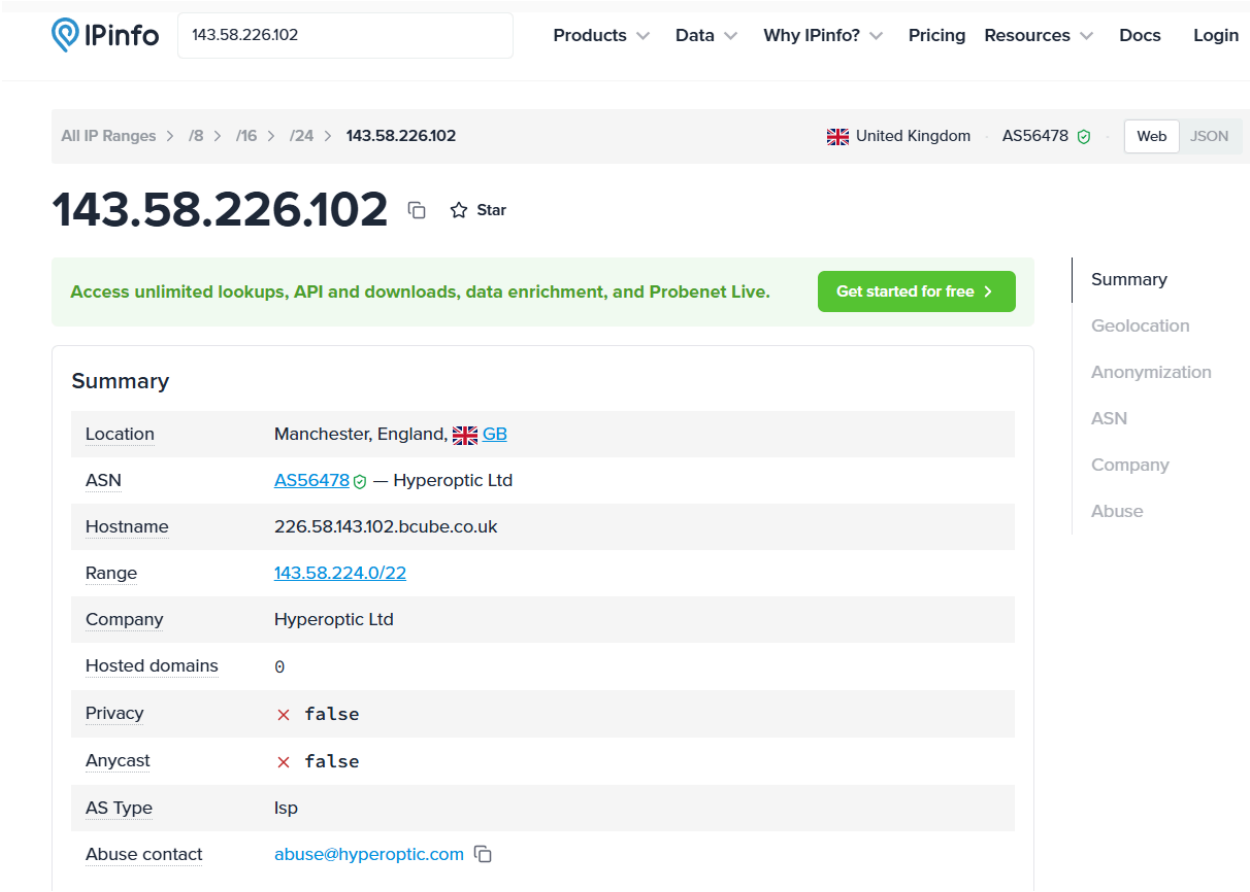
- Step 1 - Baseline establishment: Analysed sign-in and activity logs for 25–29 July 2023 to identify normal IP, working hours, application usage, and activity patterns for Erwin Smith.
- Step 2 - Anomaly detection: Scanned both log files for IP addresses deviating from the established baseline. Identified three foreign IPs: 79.124.60.6, 150.158.77.170, and 124.120.140.202.
- Step 3 - IP geolocation: Submitted all four IPs (including baseline) to ipinfo.io to determine country, city, ISP, and infrastructure type.
- Step 4 - IP reputation check: Submitted all suspicious IPs to VirusTotal for vendor detection scores, community assessments, and related file/domain intelligence.
- Step 5 - Activity log cross-reference: Cross-referenced suspicious IP activity in sign-in logs against activity logs to determine what resources were accessed or downloaded during unauthorized sessions.

- Step 6 - Anomaly correlation: Identified the malformed Request ID in sign-in logs as an additional indicator of automated tooling.
- Step 7 - File hash analysis: Submitted the caffeine.exe hash from activity logs to VirusTotal to determine whether the tool is malicious and review its behavioural characteristics.

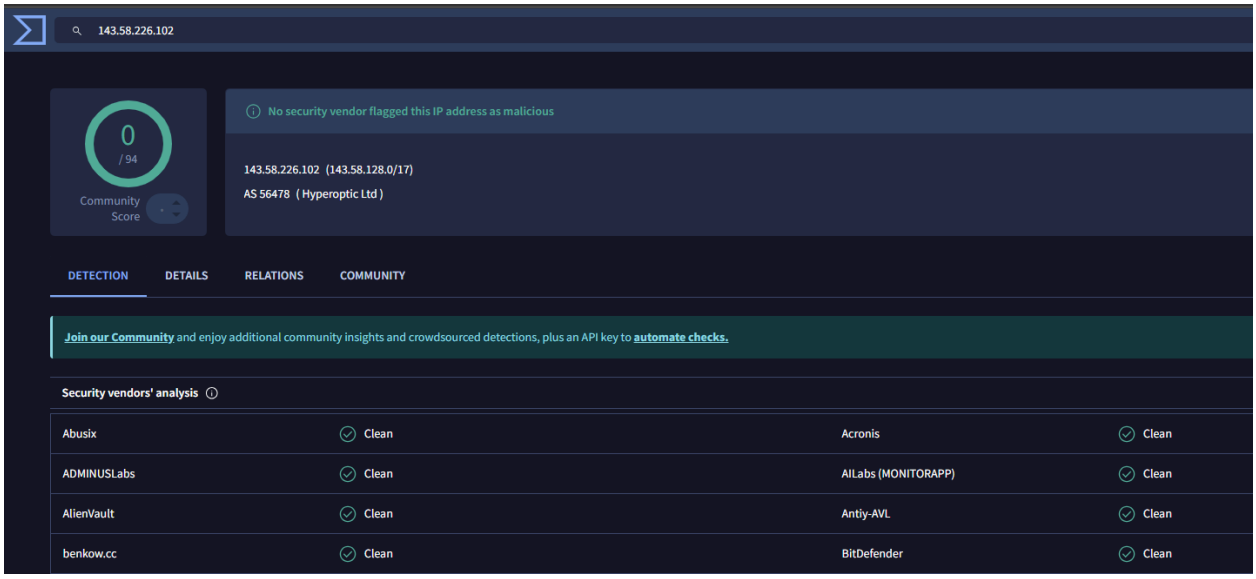
3. FINDINGS & EVIDENCE

3.1 Baseline — Legitimate Activity (25–29 July 2023)

An examination of the sign-in and activity logs from July 25 to July 29, 2023, verifies a steady and legitimate usage pattern for Erwin Smith. All activities are traced back to a single IP address, 143.58.226.102, occurring within typical UK working hours (08:00–17:15). The applications accessed align perfectly with the responsibilities of a Financial Analyst, including Microsoft Word, Excel, PowerPoint, Teams, Outlook, SharePoint, and OneDrive. Every authentication event was successful, with no failed login attempts.



ipinfo.io — 143.58.226.102 showing Manchester, England, Hyperoptic Ltd ISP



VirusTotal — 143.58.226.102 showing 0/94 detections, all vendors Clean

IP 143.58.226.102 is confirmed as a legitimate UK residential/business broadband address assigned to Hyperoptic Ltd, Manchester, England. This is Erwin Smith's known working IP and is classified as legitimate.

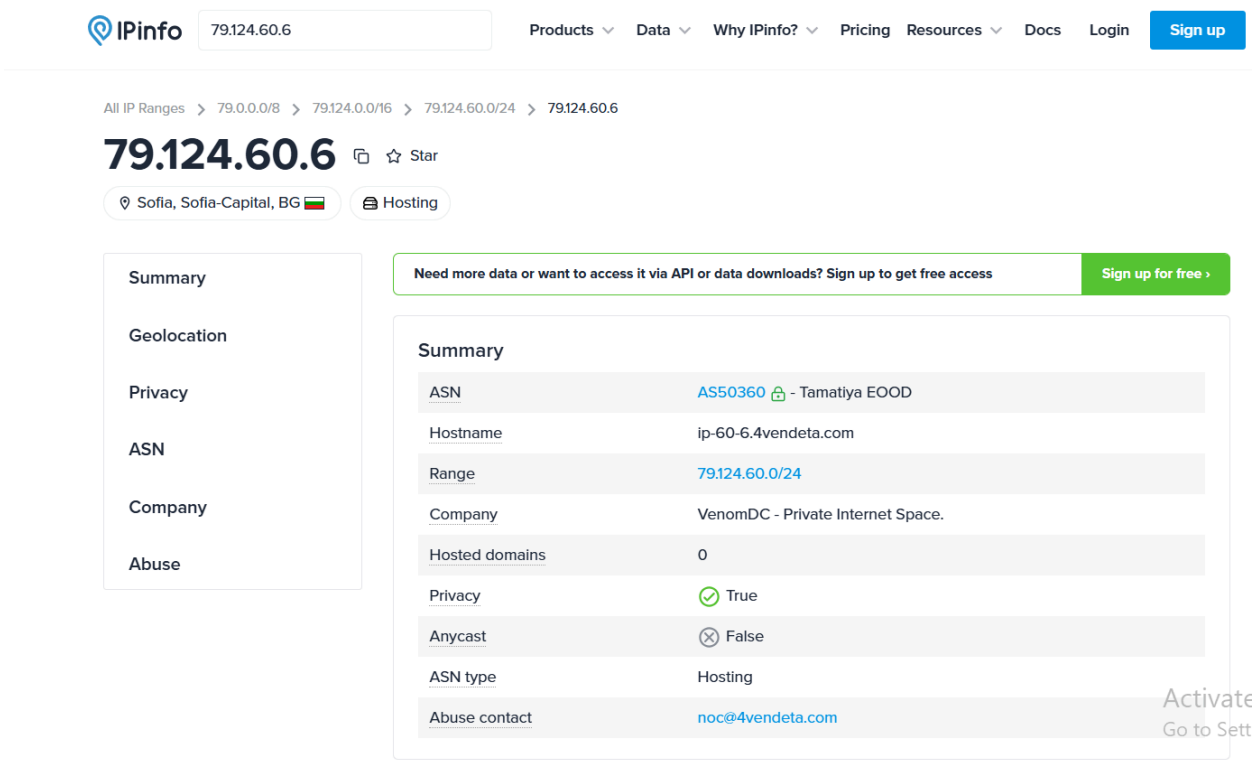
3.2 IP Address Analysis — Suspicious IPs

IP Address	Location	Provider	Type	VT Score	Verdict
143.58.226.102	Manchester, UK	Hyperoptic Ltd	ISP	0/94	**LEGITIMATE**
79.124.60.6	Sofia, Bulgaria	VenomDC (Bulletproof Hosting)	Hosting/VPS	0/94*	**MALICIOUS**
150.158.77.170	Shanghai, China	Tencent Cloud Computing	Cloud Hosting	3/94	**MALICIOUS**
124.120.140.202	Bangkok, Thailand	True Online (ISP)	ISP	0/94	**SUSPICIOUS**

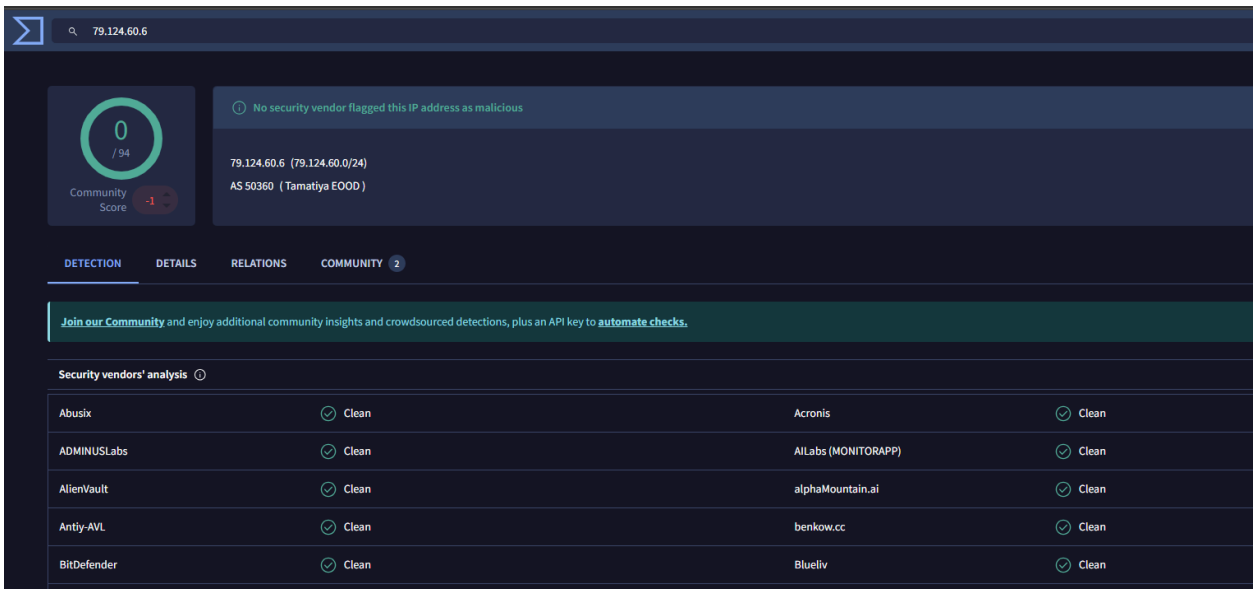
* 79.124.60.6 returns 0/94 on VirusTotal vendor detections, however classification as malicious is based on infrastructure type (bulletproof hosting), provider reputation (VenomDC), and the context of its activity in the logs. Zero vendor detection does not indicate legitimacy for targeted attack infrastructure.

IP 1 — 79.124.60.6 (Sofia, Bulgaria — VenomDC)

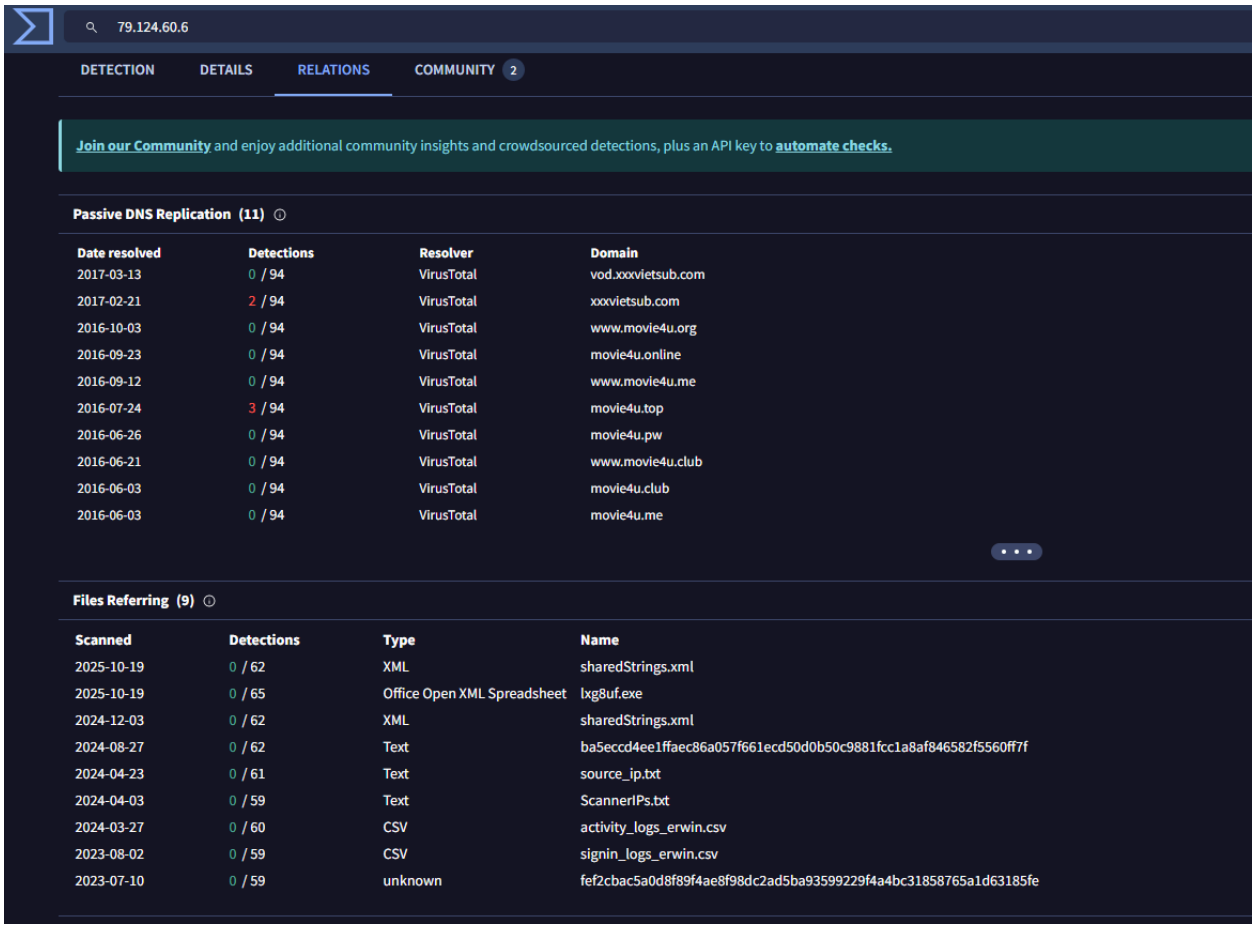
This IP belongs to VenomDC, which operates under ASN Tamatiya EOOD, and has the hostname ip-60-6.4vendeta.com. VenomDC identifies itself as a 'Private Internet Space' provider and is categorized by IPinfo as a Hosting type, rather than a consumer ISP. Providers of bulletproof hosting like VenomDC are frequently utilized by malicious actors because of their leniency towards abuse complaints and their unwillingness to cooperate with law enforcement.



ipinfo.io — 79.124.60.6 showing Sofia, Bulgaria, VenomDC Private Internet Space, Hosting type, Privacy: True



VirusTotal — 79.124.60.6 Detection tab showing 0/94, Community score -1



VirusTotal — 79.124.60.6 Relations tab showing Files Referring: activity_logs_erwin.csv, signin_logs_erwin.csv, ScannerIPs.txt, source_ip.txt

The Relations tab in VirusTotal verifies that this IP is listed in scanner IP lists and threat intelligence files related to source IPs.

Additionally, the Passive DNS history reveals a past connection with domains that have minor detections. Moreover, the inclusion of our log files (activity_logs_erwin.csv and signin_logs_erwin.csv) in the Files Referring section suggests that this IP has previously been submitted to VirusTotal as part of earlier threat intelligence sharing.

IP 2 — 150.158.77.170 (Shanghai, China — Tencent Cloud)

This IP address belongs to Tencent Cloud Computing (Beijing) Co., Ltd, a prominent cloud service provider in China. It represents cloud hosting infrastructure rather than a consumer Internet Service Provider. Typically, it would be unusual for a Financial Analyst based in the UK to access corporate systems through Chinese cloud infrastructure, given the geographical and contextual factors involved.

IPinfo | Type / to search | Products | Data | Why IPinfo? | Pricing | Resources | Docs | Login

All IP Ranges > /8 > /16 > /24 > 150.158.77.170 | China · AS45090 · Web JSON

150.158.77.170

Star | Hosting

Access unlimited lookups, API and downloads, data enrichment, and Probenet Live. Get started for free

Summary
Geolocation
Anonymization
ASN
Company
Abuse

Summary

Location	Shanghai, Shanghai, CN
ASN	AS45090 — Shenzhen Tencent Computer Systems Company Limited
Hostname	—
Range	150.158.64.0/18
Company	Tencent Cloud Computing (Beijing) Co., Ltd
Hosted domains	0
Privacy	× false
Anycast	× false
AS Type	Hosting
Abuse contact	abuse@tencent.com

ipinfo.io — 150.158.77.170 showing Shanghai, China, Tencent Cloud, Hosting type

150.158.77.170

3 / 94
Community Score -1

3/94 security vendors flagged this IP address as malicious

150.158.77.170 (150.158.0.0/16)
AS 45090 (Shenzhen Tencent Computer Systems Company Limited)

DETECTION | DETAILS | RELATIONS | COMMUNITY 17

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Crowdsourced context

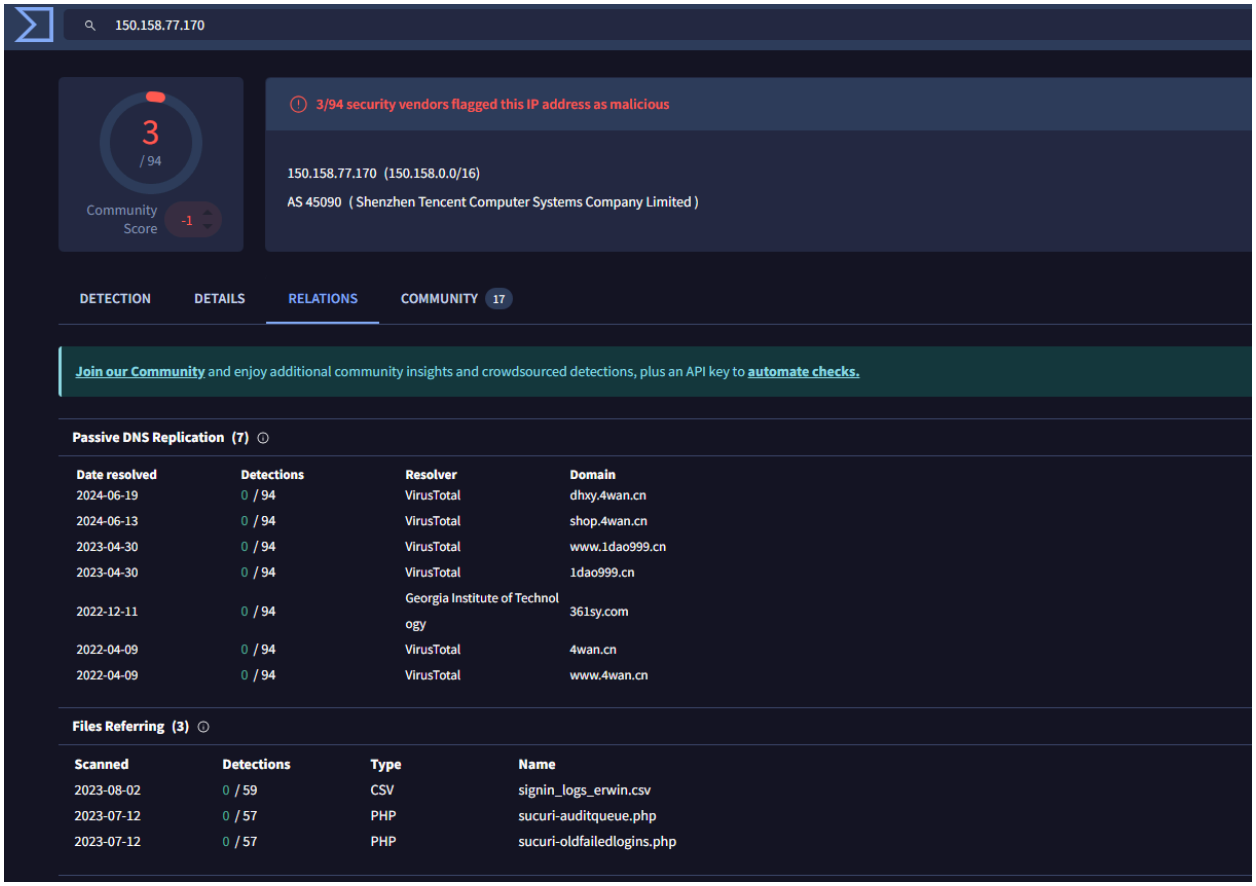
HIGH 0 | MEDIUM 0 | LOW 0 | INFO 1 | SUCCESS 0

Find more information on CrowdSec CTI · according to source CrowdSec · 1 year ago
↳ Behaviors: HTTP Bruteforce / HTTP Scan

Security vendors' analysis

ADMINUSLabs	Malicious	BitDefender	Phishing
G-Data	Phishing	alphaMountain.ai	Not Recommended

VirusTotal — 150.158.77.170 showing 3/94 detections: ADMINUSLabs Malicious, BitDefender Phishing, G-Data Phishing. CrowdSec: HTTP Bruteforce / HTTP Scan behaviour



VirusTotal — 150.158.77.170 Relations tab showing Files Referring: signin_logs_erwin.csv, sucuri-auditqueue.php, sucuri-oldfailedlogins.php

VirusTotal returns 3/94 detections with ADMINUSLabs classifying the IP as Malicious and BitDefender and G-Data both classifying it as Phishing. The CrowdSec crowdsourced context entry confirms observed behaviour of HTTP Bruteforce and HTTP Scan. this IP has been independently observed attacking web applications. The Files Referring section includes sucuri-auditqueue.php and sucuri-oldfailedlogins.php, which are web application security audit files for failed logins, further corroborating the bruteforce history. This is the most definitively malicious IP in the incident.

IP 3 — 124.120.140.202 (Bangkok, Thailand — True Online)

This IP address belongs to True Online, a reputable Thai consumer ISP (AS17552). In contrast to the other two questionable IPs, this one does not serve as hosting infrastructure; rather, it represents a residential or business broadband connection.

The login attempt originating from this IP was aimed at Azure CLI, which is a command-line interface designed for programmatic management of Azure resources, rather than a typical end-user application.

A failed login attempt on Azure CLI from an IP associated with a Thai ISP targeting a staff account of a UK company strongly suggests a credential stuffing or a targeted account takeover attempt.

IPinfo 124.120.140.202 Products Data Why IPinfo? Pricing Resources Docs Login

All IP Ranges > /8 > /16 > /24 > 124.120.140.202 Thailand AS17552 Web JSON

124.120.140.202

Star

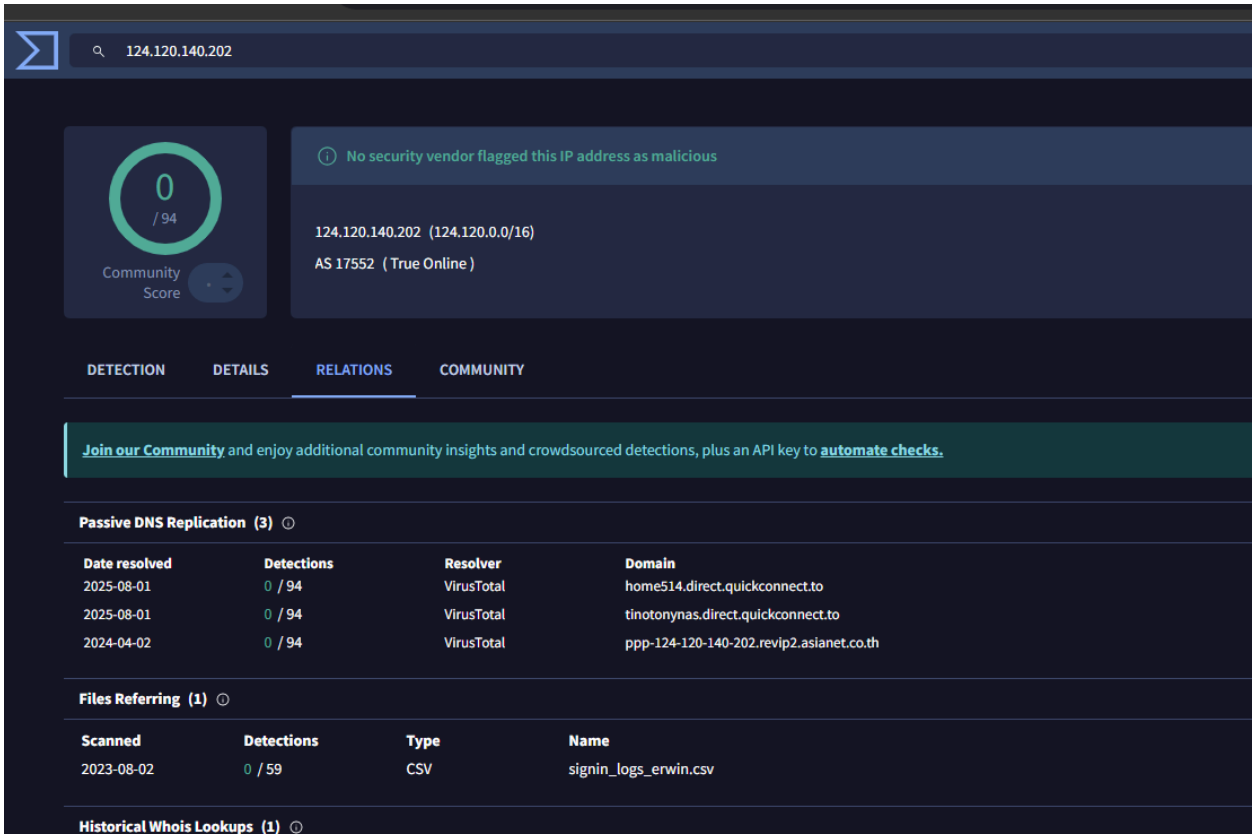
Access unlimited lookups, API and downloads, data enrichment, and Probenet Live. Get started for free

Summary
Geolocation
Anonymization
ASN
Company
Abuse

Summary

Location	Bangkok, Bangkok, TH
ASN	AS17552 — True Online
Hostname	ppp-124-120-140-202.revip2.asianet.co.th
Range	124.120.128.0/18
Company	TRUEHISP
Hosted domains	0
Privacy	× false
Anycast	× false
AS Type	Isp
Abuse contact	abuse@trueinternet.co.th

ipinfo.io — 124.120.140.202 showing Bangkok, Thailand, True Online ISP, AS17552



VirusTotal — 124.120.140.202 showing 0/94 detections, Relations tab showing Files Referring: signin_logs_erwin.csv

3.3 Attack Sequence — 30–31 July 2023

The following sign-in log analysis reconstructs the attack sequence. All timestamps are UTC.

Timestamp	IP Address	Application	Status	Classification
25/07 08:10	143.58.226.102	Microsoft Teams	Success	**LEGITIMATE**
25/07 13:35	143.58.226.102	ProjectWorkManagement	Success	**LEGITIMATE**
25/07 15:45	143.58.226.102	Microsoft OneDrive	Success	**LEGITIMATE**
26/07 09:00	143.58.226.102	Office365 Shell	Success	**LEGITIMATE**
26/07 12:20	143.58.226.102	Microsoft Teams	Success	**LEGITIMATE**
26/07 14:30	143.58.226.102	Microsoft Outlook	Success	**LEGITIMATE**
26/07 16:15	143.58.226.102	Microsoft OneDrive	Success	**LEGITIMATE**
27/07 09:30	143.58.226.102	ProjectWorkManagement	Success	**LEGITIMATE**

27/07 11:15	143.58.226.102	Microsoft OneNote	Success	**LEGITIMATE**
27/07 13:45	143.58.226.102	Microsoft SharePoint	Success	**LEGITIMATE**
27/07 15:35	143.58.226.102	Microsoft Outlook	Success	**LEGITIMATE**
27/07 17:15	143.58.226.102	ProjectWorkManagement	Success	**LEGITIMATE**
28/07 08:55	143.58.226.102	Microsoft Excel	Success	**LEGITIMATE**
28/07 10:40	143.58.226.102	Atlassian	Success	**LEGITIMATE**
28/07 12:05	143.58.226.102	Wizer Training	Success	**LEGITIMATE**
28/07 14:20	143.58.226.102	Office365 Shell	Success	**LEGITIMATE**
28/07 16:00	143.58.226.102	Office365 Shell	Success	**LEGITIMATE**
29/07 10:00	143.58.226.102	Microsoft Excel	Success	**LEGITIMATE**
29/07 14:15	143.58.226.102	Microsoft Teams	Success	**LEGITIMATE**
30/07 10:45	**79.124.60.6**	**Microsoft Exchange**	**FAILURE**	**MALICIOUS**
31/07 08:20	**79.124.60.6**	**Microsoft Outlook**	**FAILURE**	**MALICIOUS**
31/07 09:50	**150.158.77.170**	**Microsoft Online**	**SUCCESS**	**MALICIOUS**
31/07 11:30	**124.120.140.202**	**Azure CLI**	**FAILURE**	**SUSPICIOUS**
31/07 13:10	**143.58.226.102**	**Microsoft Word**	**Success**	**LEGITIMATE**
31/07 13:11	**79.124.60.6**	**Microsoft SharePoint**	**SUCCESS**	**MALICIOUS**

The sequence of attacks indicates a well-coordinated, multi-source credential assault that took place on 31 July 2023. Initially, the attacker made two unsuccessful attempts from a Bulgarian VPS (79.124.60.6) before managing to authenticate through a Chinese Tencent Cloud IP (150.158.77.170) at 09:50. Meanwhile, a different actor or tool tried to gain Azure CLI access from a Thai IP (124.120.140.202) at 11:30, but this attempt was unsuccessful. Later, the Bulgarian VPS successfully logged into SharePoint at 13:11. Notably, Erwin's legitimate UK IP (143.58.226.102) also recorded a successful Microsoft Word login at 13:10, just one minute prior to the attacker's SharePoint login, indicating that Erwin was actively engaged while his account was being accessed by the attacker.

Malformed Request ID

The sign-in log entry dated 31/07 at 13:11 features a non-standard Request ID: 'Sdfvasdfv-9423-fsafda-asd-sdafsfsadf'. In contrast, all other Request IDs in the log adhere to the standard UUID format (for instance, 3e3a203d-37f2-4ce4-bc93-8bfb205ecc04). This irregular identifier suggests that automated tools were involved, failing to produce a valid GUID, which further implies that the login was executed by an attack script instead of a human using a web browser.

3.4 Data Accessed & Exfiltrated

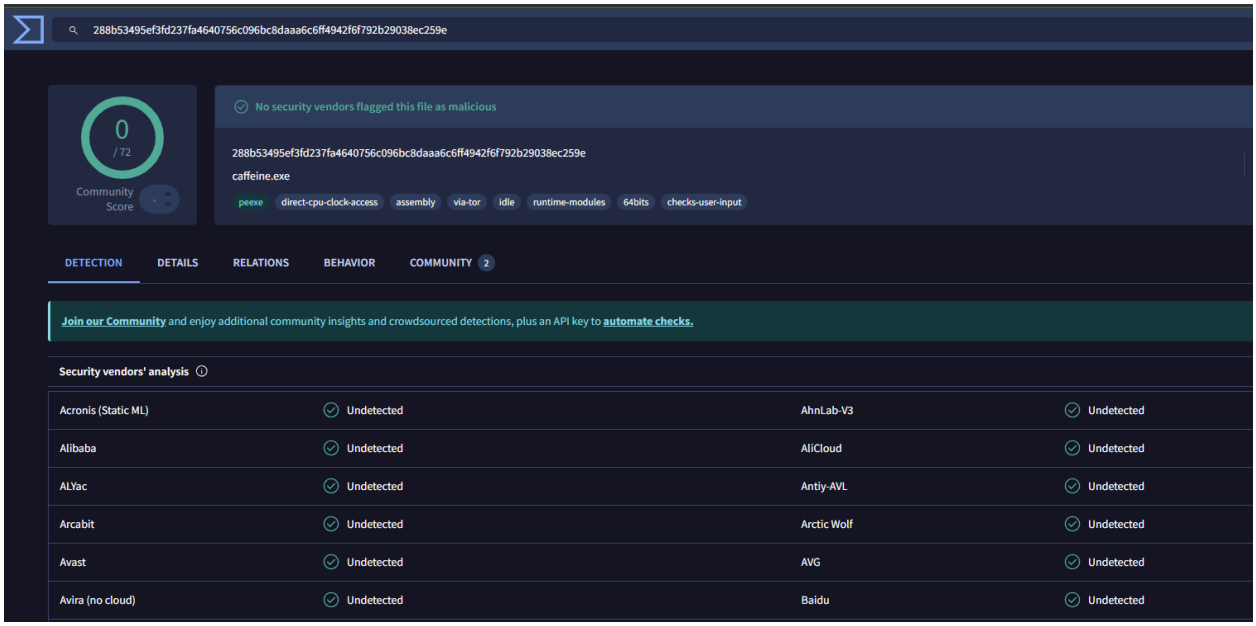
Cross-referencing activity logs with the suspicious IP addresses identified two instances of sensitive data access by the attacker from IP 79.124.60.6:

Timestamp	IP Address	Application	Event	Resource
31/07 10:20	**79.124.60.6**	**SharePoint**	**File Access**	**vulnerability_report_June2023.docx**
31/07 17:10	**79.124.60.6**	**SharePoint**	**File DOWNLOAD**	**updated_payroll.xlsx**

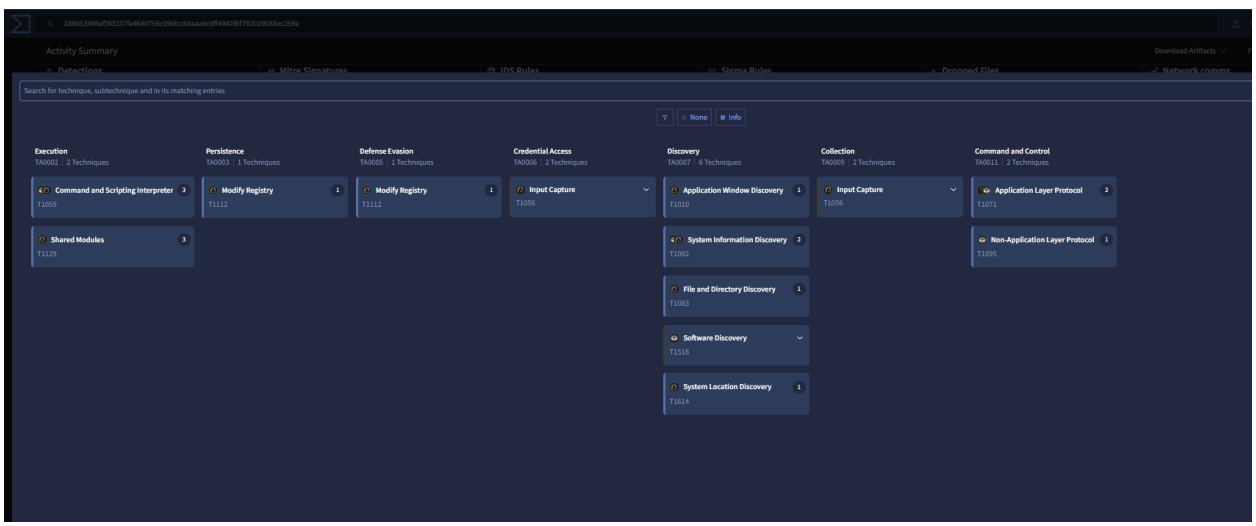
- vulnerability_report_June2023.docx - This document contains the organisation's known security vulnerabilities as of June 2023. An attacker with this document gains knowledge of unpatched systems and exploitable weaknesses, enabling targeted follow-on attacks. This is a critical intelligence loss.
- updated_payroll.xlsx - This document contains staff salary and personal financial data. As a Financial Analyst, Erwin has legitimate access to this file, but its download by the attacker constitutes a data breach with potential regulatory implications under UK GDPR.

3.5 Additional Finding — Unauthorised Software (caffeine.exe)

The activity log entry for 25/07/2023 17:10 records the execution of caffeine.exe from the Desktop directory, logged under the application category 'Mouse Jiggler'. The SHA256 hash 288b53495ef3fd237fa4640756c096bc8daaa6c6ff4942f6f792b29038ec259e was submitted to VirusTotal.



VirusTotal — caffeine.exe hash showing 0/72 detections, filename confirmed as caffeine.exe, tags: peexe, direct-cpu-clock-access, idle, checks-user-input



VirusTotal — caffeine.exe Behaviour/MITRE ATT&CK tab showing Persistence: Modify Registry (T1112), Defense Evasion: Modify Registry, Credential Access: Input Capture (T1056), Discovery: multiple techniques, C2: Application Layer Protocol (T1071)

caffeine.exe is not classified as malware - VirusTotal shows 0 out of 72 detections, and it is recognized as a legitimate utility for mouse jiggling. Nevertheless, having it on a corporate device breaches policy for several reasons:

- caffeine.exe stops the screen from locking when idle, circumventing the organization's idle timeout security measures.
- The MITRE ATT&CK behavioral sandbox analysis reveals registry modifications (T1112) and input capture (T1056) activities - actions that would trigger alerts from endpoint

detection systems and indicate techniques for evading defenses and accessing credentials, irrespective of the tool's legitimate status.
- The application was installed on the Desktop (Desktop/caffeine.exe) and was run during work hours, implying that the user intentionally installed it.

Regardless of whether this tool played a role in the account compromise, its existence necessitates a discussion with Erwin Smith and an examination of his device for any other unauthorized applications.

4. Indicators Of Compromise (IOCs)

Type	Value	Source	Context
IP Address	79.124.60.6	Sign-in logs / IPinfo	Bulgaria VenomDC bulletproof VPS - attack relay
IP Address	150.158.77.170	Sign-in logs / VirusTotal	China Tencent Cloud - confirmed malicious, HTTP brute force
IP Address	124.120.140.202	Sign-in logs / IPinfo	Thailand True Online ISP - Azure CLI attack attempt
File Hash (SHA256)	288b53495ef3fd237fa4640756c096bc8daaa6c6ff4942f6f792b29038ec259e	Activity logs / VT	caffeine.exe - mouse jiggler, policy violation
File	updated_payroll.xlsx	Activity logs	Sensitive payroll data - downloaded by attacker
File	vulnerability_report_June2023.docx	Activity logs	Security vulnerability report - accessed by attacker
Request ID	Sdfvasdfv-9423-fsafda-asd-sdafsfsadf	Sign-in logs	Malformed UUID - indicator of automated tooling

5. Response Actions

5.1 Immediate Containment

- Reset Erwin Smith's Microsoft 365 credentials immediately, all passwords and MFA tokens.
- Revoke all active sessions for Erwin's account across all Microsoft 365 services.
- Block the following IPs at the firewall and Conditional Access policies: 79.124.60.6, 150.158.77.170, 124.120.140.202.
- Place Erwin's account under enhanced monitoring, flag any login from non-UK IPs.

5.2 Investigation & Eradication

- Determine how Erwin's credentials were obtained, review whether he received a phishing email (note: the Task 1 campaign targeted other staff on 29 July 2023, one day before the first suspicious login attempt on 30 July). Check Erwin's inbox for phishing emails in the same timeframe.
- Assess whether the vulnerability_report_June2023.docx contents have been acted upon, check for any new suspicious activity against systems listed in that report.
- Notify the Data Protection Officer of the payroll data breach (updated_payroll.xlsx downloaded), assess UK GDPR notification obligations.
- Remove caffeine.exe from Erwin's device. Conduct a full device audit for other unauthorized software.
- Check whether any of the three suspicious IPs attempted to access other staff accounts.

5.3 Long-Term Recommendations

- Implement Conditional Access policies in Azure AD/Entra ID to block logins from outside the UK or from known hosting/VPS IP ranges.
- Enable Microsoft Defender for Identity to detect impossible travel and unfamiliar sign-in properties automatically.
- Enforce phishing-resistant MFA (hardware token or passkey) for all staff with access to sensitive financial or security documents.
- Implement sensitivity labels on documents classified as confidential (payroll, vulnerability reports) and enable audit alerts for download events.
- Establish a policy prohibiting unauthorised software on corporate devices and enforce it via endpoint management (Intune/MDM).

6. COMMUNICATION STRATEGY

6.1 To Erwin Smith

To: Erwin SmithSubject: URGENT — Security Alert on Your Account

Hi Erwin, our Security Operations team has detected unauthorized access to your Microsoft 365 account from overseas IP addresses on 31 July 2023. As a precaution, we are resetting your account credentials and revoking all active sessions. You will receive a password reset link shortly. Please do not use your current password on any other services. We will contact you today to discuss next steps, including a review of your work device. Please do not share or discuss the details of this incident with colleagues until further notice.

6.2 To CISO / Management

To: Marshall D Teach (CISO)Subject: CRITICAL — Confirmed Account Compromise and Data Exfiltration (Erwin Smith)

This is to notify you of a confirmed credential compromise and data exfiltration incident affecting the account of Erwin Smith, Financial Analyst. On 31 July 2023, an unauthorised third party accessed Erwin's Microsoft 365 account from Bulgarian and Chinese cloud infrastructure and downloaded two sensitive documents: the June 2023 vulnerability report and the current payroll spreadsheet. Immediate credential reset and session revocation have been initiated. A full investigation report is attached. Potential UK GDPR notification obligations are under assessment due to the payroll data exfiltration. Recommended next steps are detailed in Section 5 of the attached report.

6.3 To Affected Staff (Payroll)

Staff whose data may have been compromised in the payroll file should be notified in line with the organisation's data breach notification procedure and UK GDPR obligations. Individual notifications should be coordinated through the Data Protection Officer and should not be sent until the scope of data in the payroll file is confirmed.

6.4 Cross-Incident Correlation — Link to Task 2 Phishing Campaign

It has been observed that the phishing campaign outlined in Task 2 targeted several staff members on 29 July 2023, the day right before the first suspicious login attempt on Erwin Smith's account (30 July 2023, 10:45 UTC). This timing seems unlikely to be a coincidence.

Although Erwin Smith was not one of the five staff members who reported phishing emails in Task 2, his lack of inclusion in the reported cases does not rule out the possibility that he was targeted. It may suggest that he received a phishing email and engaged with it without realizing or reporting it. The credential theft that led to this breach required the attacker to acquire Erwin's username and password before 30 July. Phishing is still the most likely method used.

In light of the ongoing investigation, the following steps are advised: examine Erwin Smith's inbox for any emails received between 25–29 July 2023 that match the characteristics of the Task 1 campaign (sender domains alfredegov@gmail.com, zelatcol@gmail.com, kanzalshamsprojectmgt.com, or links to wtools.io, Google Drive download URLs, or domains hosted by Contabo); verify if any of the Task 1 phishing emails reached Erwin's mailbox but went unreported; and correlate the execution timestamp of caffeine.exe (25 July 17:10) with any suspicious email received on that same date.

If a link between the Task 1 campaign and this credential compromise is confirmed, these incidents should be treated as a single coordinated attack against the organisation rather than separate events, and the threat actor assessment should be escalated accordingly.